Лекция 13. Документация, безопасность и ответственное применение ML

Версия: 2026–2027 учебный год

Продолжительность: 2 академических часа

Связанные работы: ЛР13 «Point-in-time признаки», ЛР14 «Документация, безопасность и Responsible ML»

1. Цель лекции

Показать, как превратить утверждения о модели в проверяемые release evidence: model card, data card, групповые метрики, threat model, проверку лицензий и ответственное решение о выпуске. Студент должен различать наличие документа и подтверждённый контроль.

2. Результаты обучения

Студент сможет:

• описать назначение, пользователей и недопустимые сценарии модели;

• связать model card с конкретной версией данных, кода, модели и threshold;

• оценить качество по группам и учесть малый размер выборки;

• объяснить, почему одна метрика или один gap не доказывает fairness;

• построить простой threat model и определить границы доверия;

• организовать работу с секретами, логами, зависимостями и лицензиями;

• применить Govern–Map–Measure–Manage к учебному release;

• принять решение release, review, stop или rollback с указанием владельца.

3. Место в сквозном проекте

К этому моменту команда умеет воспроизводить данные и модель, выпускать сервис, наблюдать его и контролировать временную корректность признаков. ЛР14 отвечает на следующий вопрос: достаточно ли у нас контекста, доказательств и контроля риска, чтобы разрешить очередной выпуск?

4. Документация как часть системы

Документ полезен, если он version-controlled, проходит review, ссылается на фактические артефакты и может остановить pipeline. Карточка с общими фразами, не связанная с model version и test period, создаёт ложное чувство контроля. Поэтому обязательные разделы проверяются в CI, а содержательное решение остаётся за человеком.

5. Четыре уровня доказательства

1. Утверждение: «модель пригодна для учебного сценария».

2. Измерение: метрика с определённым набором, периодом и threshold.

3. Артефакт: JSON, карточка, commit SHA, model version и логи CI.

4. Решение: кто и на основании какой policy разрешил или остановил выпуск.

Отсутствие любого уровня делает цепочку аудита неполной.

6. Model card

Model card объясняет, что представляет собой модель, для чего она предназначена, как оценивалась и

где её использование опасно. Это не рекламный паспорт качества. Карточка должна помогать разработчику, владельцу процесса, reviewer и пользователю принять обоснованное решение.

7. Обязательные разделы model card

Для курса обязательны: краткое описание; назначение; недопустимое использование; модель и данные; оценка качества; групповые метрики; ограничения и риски; мониторинг и реакция; безопасность и конфиденциальность; надзор человека; владелец и журнал изменений.

8. Intended use и out-of-scope

Фраза «прогноз задержки» слишком широка. Нужны момент решения, пользователь, действие и допустимый масштаб. В учебном проекте разрешена демонстрация за 60 минут до вылета. Решения о безопасности, компенсациях, работниках или реальной эксплуатации явно запрещены.

9. Версия и provenance

Model card связывается с commit SHA, model registry version, data/feature contract, test window, threshold и release manifest. Если карточка описывает «последнюю модель», её невозможно проверить после следующего выпуска. Источник данных и право использования входят в provenance наравне с hash.

10. Data card

Data card описывает происхождение, назначение, схему, сбор, качество, временное разбиение, права, хранение и известные ограничения. Контракт отвечает «что машина проверяет», карточка — «что это означает и почему допустимо». Эти документы дополняют, а не заменяют друг друга.

11. Минимизация и хранение данных

Собирать нужно только поля, необходимые для заявленного сценария. Для каждого внешнего источника фиксируются владелец, основание использования, срок хранения, удаление и получатели. Учебный проект использует синтетические данные и не даёт разрешения добавлять реальные персональные сведения.

12. Порог и стоимость ошибок

Threshold преобразует вероятность в действие. Его нельзя выбирать только по максимальному F1: ложноположительная и ложноотрицательная ошибки имеют разную стоимость. Изменение threshold меняет precision, recall, нагрузку на оператора и групповые различия, поэтому считается изменением policy.

13. Зачем нужны групповые метрики

Среднее качество может скрыть сегмент, где модель систематически ошибается. Группы выбираются не потому, что столбец доступен, а по гипотезе риска и предполагаемому воздействию. Сначала фиксируется вопрос, затем набор, метрика и критерий решения.

14. Учебный безопасный сегмент

В курсе используется `IsWeekend`, чтобы отработать вычисление, minimum support и CI gate без обработки чувствительных атрибутов. Это операционный сегмент, не защищённая группа. Результат нельзя называть оценкой дискриминации или переносить на людей.

15. Минимальный размер группы

Метрика на двух строках математически вычислима, но неустойчива и может раскрывать отдельные

наблюдения. Policy задаёт minimum group rows. Недостаточная группа получает статус `insufficient_sample`; её значение не публикуется и не заменяется нулём.

16. Что сравнивать

Для каждой достаточной группы сохраняются n, доля положительного класса, доля положительных предсказаний, precision, recall, F1 и ROC AUC, если присутствуют оба класса. Gap имеет смысл только вместе с объёмами, доверительными интервалами, базовыми частотами и стоимостью ошибок.

17. Почему parity не равна fairness

Одинаковый F1 может скрывать разные recall и false-positive rate. Равенство конкретной метрики может противоречить другой цели. Защищённый атрибут может отсутствовать, быть неточным или иметь proxy. Fairness является контекстным социотехническим требованием, а не одним универсальным числом.

18. Решение при нарушении gate

Нарушение порога переводит выпуск в review, а не автоматически доказывает вред. Команда проверяет качество данных, размер и период группы, threshold, стоимость ошибки и альтернативы. Возможные решения: собрать данные, изменить сценарий, ограничить использование, откалибровать модель или остановить выпуск.

19. NIST AI RMF

AI RMF организует работу вокруг четырёх функций. Govern задаёт роли, policy и культуру риска; Map — контекст, участников и возможный вред; Measure — методы и evidence; Manage — приоритеты, реакцию и мониторинг. Govern является сквозной функцией. Это не линейный универсальный чек-лист.

20. Применение RMF к проекту

Govern: CODEOWNERS, policy, владелец и stop authority. Map: пользователи, out-of-scope, данные, границы и затронутые стороны. Measure: метрики, тесты, threat model и completeness audit. Manage: release decision, mitigation, monitoring, incident response и rollback.

21. Threat modeling

Threat model начинает не с продукта-сканера, а с активов, границ доверия, злоумышленника и последствия. Для ML-сервиса активами являются код, данные, модель, registry, credentials, CI и логи. Угрозы включают утечку секрета, poisoning, подмену артефакта, supply-chain и избыточный лог.

22. Секреты

Секрет не хранится в репозитории, `.env.example` содержит только имена и безопасные заполнители. Secret scanning и push protection снижают риск случайного commit, но не заменяют rotation. После утечки секрет сначала отзывают или меняют, затем исправляют историю и источник появления.

23. Безопасные логи

Observability следует принципу allowlist: записываются request ID, route template, status, latency и версия модели, но не сырые признаки, token, пароль или персональные данные. Нельзя сначала собрать всё, а потом надеяться удалить чувствительные поля.

24. Цепочка поставки и лицензии

SBOM отвечает, что вошло в артефакт; сканер — какие известные проблемы найдены; license review — можно ли распространять компонент выбранным способом. Версия и лицензия проверяются по фактическому пакету и официальному источнику. Неизвестный статус блокирует release.

25. Human oversight

Автоматический gate хорошо обнаруживает неполный заголовок или превышенный gap. Он не понимает общественную цену ошибки и законность сценария. Ответственный человек должен иметь контекст, полномочие остановить выпуск и альтернативу модели — например, ручную обработку или отказ.

26. Демонстрация преподавателя

1. Запустить `mlops_flight_delay.governance` на baseline.
2. Показать overall и две группы с n.
3. Удалить строки одной группы и получить `insufficient_sample`.
4. Удалить заголовок model card и показать fail completeness check.
5. Изменить threshold и обсудить метрики/стоимость ошибок.
6. Открыть threat model и проследить одну угрозу до контроля и residual risk.

27. Вопросы аудитории

1. Почему наличие model card не доказывает безопасность?
2. Что изменится при новом threshold?
3. Почему малую группу нельзя публиковать как обычную метрику?
4. Можно ли считать равный F1 доказательством fairness?
5. Чем data contract отличается от data card?
6. Что делать первым после утечки секрета?
7. Зачем threat model содержит остаточный риск?
8. Кто имеет право остановить учебный release?

28. Связь с ЛР14 и ЛР15

В ЛР14 команда создаёт и проверяет release evidence. В ЛР15 эти ограничения войдут в нагрузочное и масштабное решение: производительность и стоимость нельзя оптимизировать без SLO, security и ответственного назначения системы.

29. Официальные источники

• NIST AI RMF: https://www.nist.gov/itl/ai-risk-management-framework

• NIST AI RMF Core: https://airc.nist.gov/airmf-resources/airmf/5-sec-core/

• Model Card Toolkit repository (архивирован; источник структуры, не новая зависимость): https://github.com/tensorflow/model-card-toolkit

• GitHub secret security: https://docs.github.com/en/code-security/concepts/secret-security

• scikit-learn model evaluation: https://scikit-learn.org/stable/modules/model_evaluation.html